Lección 14 - Análisis dinámico de malware

Del comportamiento observado al veredicto

Material de estudio autocontenido para entornos controlados.

Gemini Notebook

DE LA CAPACIDAD AL COMPORTAMIENTO

ANÁLISIS ESTÁTICO

ENFOQUE: CAPACIDADES

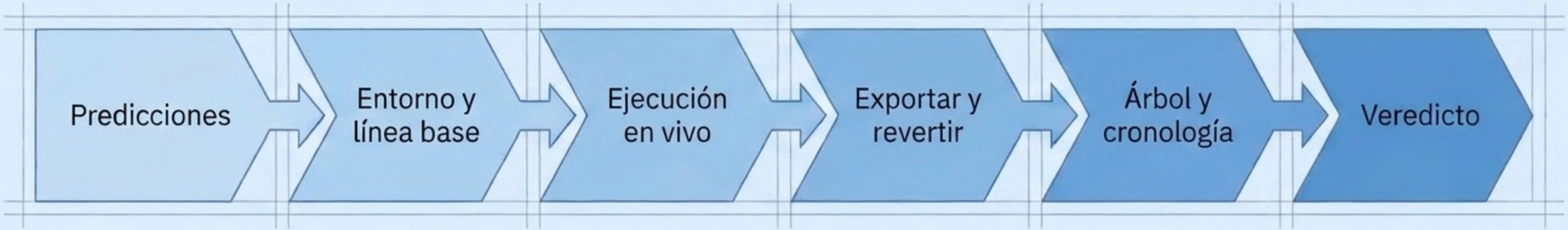
- ✓ Lenguaje: “Contiene, es compatible con”
- ✓ Límite: “No ve el comportamiento real.”

ANÁLISIS DINÁMICO

ENFOQUE: HECHOS

- ✓ Lenguaje: “Creó, escribió, se conectó.”
- ✓ Límite: solo ve esa ejecución, en ese entorno, durante esa ventana

El análisis dinámico ve solo esa ejecución, en ese entorno, en esa ventana de tiempo.



Gemini Notebook

Los 7 Elementos del Entorno Controlado (NIST SP 800-83)



VM Desechable:
Lo dañado no importa.



Snapshot Previo:
Permite volver al punto de partida exacto.



Red Simulada:
La muestra cree tener Internet sin alcanzar a nadie real.



Usuario sin Privilegios:
Separa permisos de monitoreo (elevados) del malware.



Monitoreo Definido:
Lo no configurado simplemente no se registra.



Condiciones de Detención:
Evita el descontrol (tiempo, salida de red).



Reversión Verificada:
Sin ella, el entorno limpio es solo un supuesto.

El protocolo es evidencia. El registro sistemático de cómo, dónde y quién ejecutó la prueba es vital para poder interpretar cualquier captura.

Gemini Notebook

El laboratorio de la práctica

Kali Linux (Receptor/Simulador)

- `INetSim (simula web)`
- `dnsmasq (resuelve DNS)`
- `Wireshark (captura)`
- `SMB (recibe evidencia)`

Red Interna lab_malware

(Aislada sin Internet real)

Windows VM (Ejecutor desechable)

- `Ejecución de muestra`
- `Monitoreo Sysinternals`

Caja de Concepto Crítico

Responder no es existir

Definición: El simulador INetSim responde HTTP 200 a cualquier solicitud web.

Ejemplo: INetSim responde 200 a una solicitud a pagos-sync.cerro-verde.invalid

Qué NO Afirma: Esta respuesta 200 no prueba que exista un servidor real en Internet ni revela qué haría.

Arquitectura inspirada en modelos de referencia como REMnux y FLARE-VM.

Gemini Notebook

Secuencia segura de ejecución

1. Tomar Snapshot
2. Verificar Hash SHA-256 de la muestra
3. Activar Simulador de red y Captura
4. Línea base: guardar el estado de Autoruns, Process Monitor capturando y Process Explorer abierto
5. Ejecutar la muestra (sin elevar privilegios)
6. Observar comportamiento en vivo
7. Revertir el Snapshot
8. Verificar la reversión (confirmar limpieza total)

EXPORTAR evidencia junto con su hash SHA-256 **ANTES** de revertir.
Lo que no se exporta aquí, se pierde para siempre.

Condiciones de detención obligatoria:

- Tráfico fuera de la subred aislada
- Hash incorrecto
- Tiempo de ventana excedido (>6 minutos)
- La VM tiene salida a Internet

Gemini Notebook

Qué ve y qué no ve cada herramienta

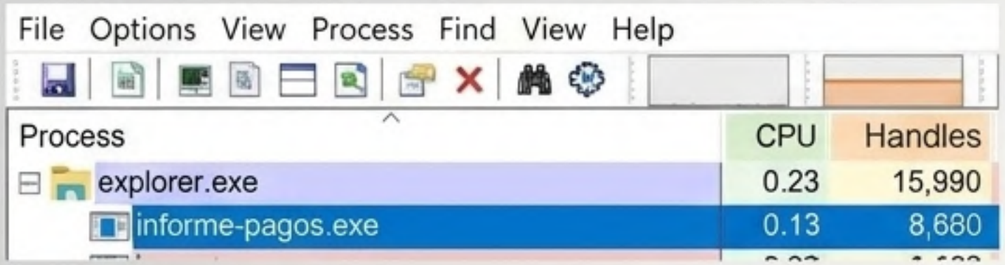
Herramienta	Mira	Ve	NO Ve
`Process Monitor`	Sistema/Red evento a evento	Historia completa ⚠️	Objetos en memoria viva o el contenido de la red.
`Process Explorer`	Procesos vivos	Árbol actual y handles abiertos ⚠️	La historia pasada (procesos muertos).
`Autoruns`	Inicio automático	Claves nuevas vs. línea base ⚠️	Si el programa realmente llegó a ejecutarse.
`Wireshark`	Red en bruto	Paquetes y su contenido si no va cifrado ⚠️	Qué proceso interno envió qué paquete.
`INetSim/dnsmasq`	Internet simulado	Solicitudes recibidas ⚠️	Tráfico interno de Windows.

Regla de Oro
Cuando se pueda, confirmar un hecho con dos fuentes independientes (Ej. TCP Connect en Procmon + solicitud capturada en INetSim).

Gemini Notebook

Observar en vivo: Process Explorer y Autoruns

Process Explorer (En vivo)



Buscar el mutex con **Find > Find Handle or DLL** (Ctrl+F)

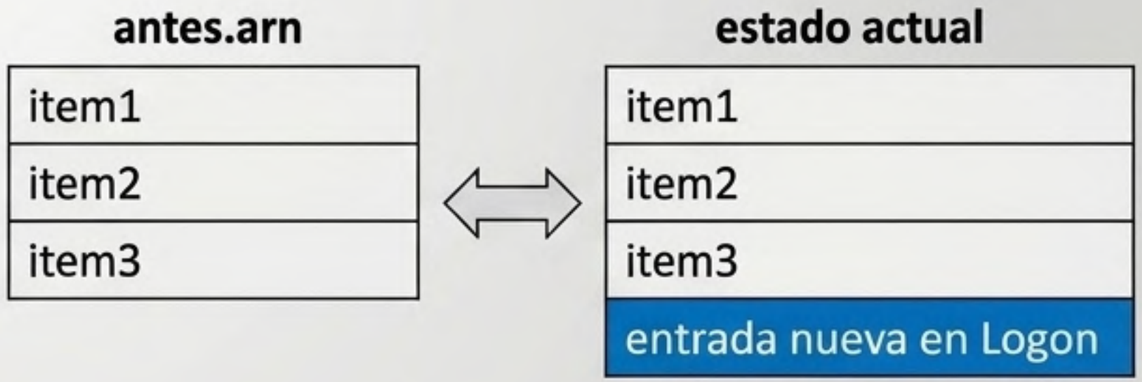
Concepto Clave: **Mutex** (Mutant)
Ejemplo: \BaseNamedObjects\Ejemplo_Mutex

Un mutex solo se ve mientras el proceso existe: si se busca después de que la muestra terminó, no aparece. Tener un mutex no prueba que la muestra intente evadir el análisis

Kill Process Tree: detener la muestra y sus hijos si se cumple una condición de detención

Autoruns

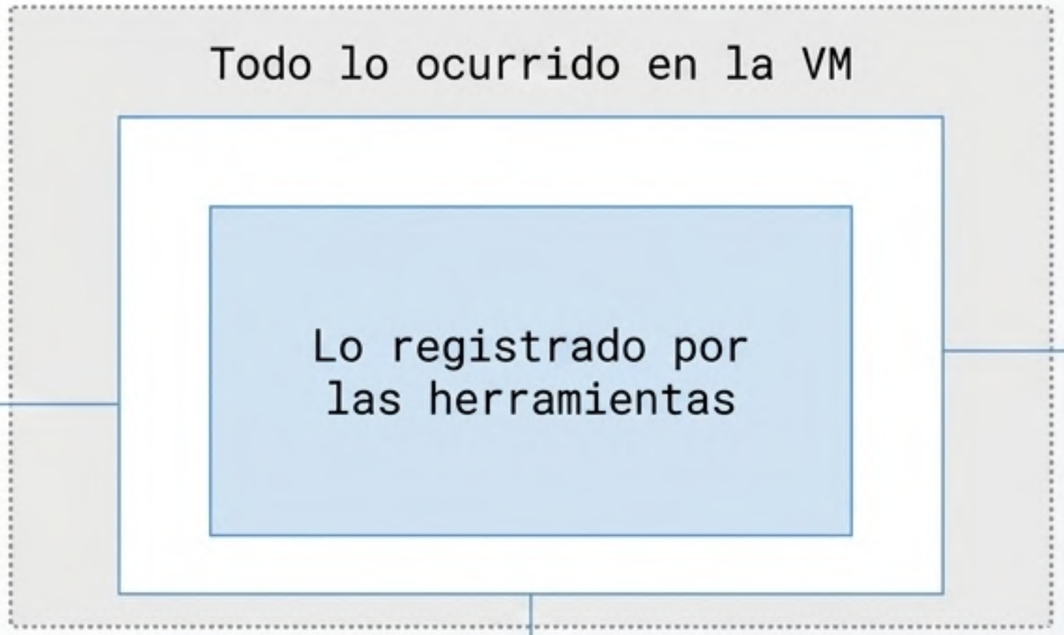
1) Antes de ejecutar: **File > Save** (**antes.arn**)
2) Durante la ejecución: **F5** y **File > Compare** contra **antes.arn**
3) Revisar la pestaña **Logon**: la fila nueva aparece resaltada



Gemini Notebook

No observado no significa no ocurrió.

Los Tres Límites de la Traza:



1. Cobertura: La herramienta no mide eso (Ej. Procmon no ve un mutex).

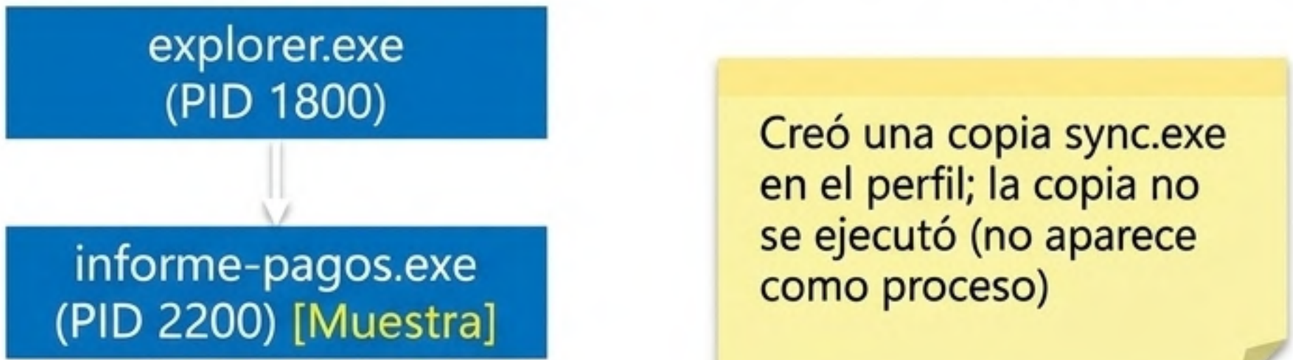
2. Ventana de tiempo: La muestra esperó o condicionó su acción a un reinicio que no ocurrió.

3. Entorno: El malware detectó la VM o se detuvo al faltar un servidor real esperado.

Glosario Forense	
No observado: Había una herramienta activa capaz de verlo, en esa ventana de tiempo, pero no apareció.	**No evaluable:** Ninguna herramienta en uso cubría ese evento (Ej. intentar ver un mutex usando solo Procmon).

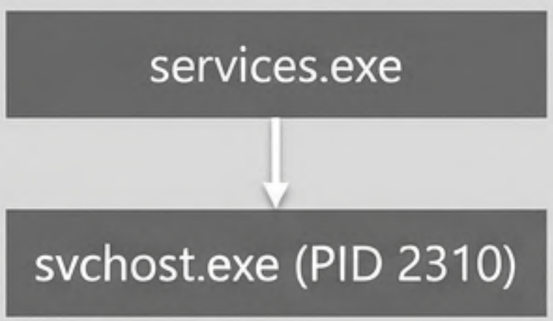
Gemini Notebook

Árbol de procesos del ejemplo CERRO VERDE



Creó una copia sync.exe en el perfil; la copia no se ejecutó (no aparece como proceso)

Ruido de Windows



Filtro en Procmon
Tools > Process Tree, seleccionar la muestra (PID 2200) e Include Subtree: quedan la muestra y sus descendientes

Reglas de Interpretación

1) Solo pertenece a la muestra lo que desciende de su PID.

2) Los PID se reutilizan: combinarlos con la hora de creación.

3) El padre da el contexto: un cmd.exe hijo de un supuesto PDF es inusual.

Gemini Notebook

Leer una fila de Process Monitor

Operaciones Clave a Filtrar:

Process Create, CreateFile, WriteFile, RegSetValue, TCP Connect.

Process Name	PID	Operation	Path	Result	Detail
informe-pagos.exe	2200	CreateFile	C:\Users\lab\AppData\Local\cv\sync.exe	SUCCESS	Desired Access: Generic Read, Disposition: Open, Options:...

Diccionario de Resultados:

- SUCCESS: La operación se concretó con éxito.
- NAME NOT FOUND: El proceso buscó el objeto y no estaba. NO significa que lo haya creado.

Advertencia Metodológica

Un evento `CreateFile` también sirve para **ABRIR archivos existentes**. Para afirmar que ocurrió una 'autocopia exacta', los eventos de archivo no bastan: se debe probar exportando los archivos físicos y comparando sus hashes criptográficos.

Gemini Notebook

El Punto Ciego del DNS: Problema de Visibilidad



El Mecanismo Delegado

El servicio Cliente DNS (svchost.exe) actúa por encargo del proceso de la muestra.

Dónde encontrar la evidencia

En el pcap de Wireshark y en los logs de dnsmasq. No visible en Procmon con el filtro de la muestra.

Alternativa: Sysmon (evento 22)

puede atribuir la consulta al proceso si estaba instalado y configurado; en esta práctica no se usa

Precaución (Ruido Inherente)

Windows genera tráfico legítimo (msftconnecttest, wpad). No se debe atribuir este tráfico al malware simplemente por compartir IP.

Gemini Notebook

Cronología de comportamiento: hechos, no intenciones

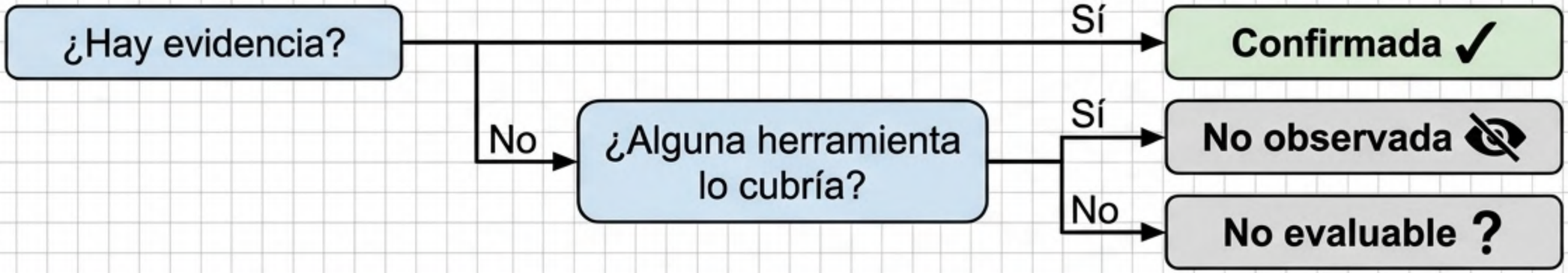
Bien escrita (Hechos Crudos): 09:00:01 - Procmon - informe-pagos.exe (PID 2200) escribió HKCU\...\Run\PagosSync apuntando a ...\cv\sync.exe

Mal escrita (Intención subjetiva): El malware logró persistencia para robar datos.

Clave Run: es compatible con persistencia, pero no prueba que se ejecute al reiniciar	**cmd.exe de descubrimiento** El simple hecho de abrirlo no basta; hay que registrar qué comandos exactos se pasaron.
Autocopia: compatible con preparar persistencia; no prueba que la copia se ejecutó; se verifica comparando hashes	**Envío de datos** ¿Qué bytes específicos se enviaron? (Verificar cruzando con Follow Stream en Wireshark).
Balizamiento (Beaconing)… No afirma malicia por sí solo; la telemetría legítima de Windows también tiene patrones periódicos estrictos. Se reconoce midiendo el intervalo entre solicitudes (por ejemplo, cada 30 s)	

Gemini Notebook

Contraste: predicción frente a observación



Confirmada ✓	No observada	No evaluable ?
Escritura en clave de registro (Evidencia: Procmon RegSetValue). Ojo: Confirmación parcial (no se comprobó si el sistema ejecuta la copia tras un reinicio real).	Hipótesis estática de “instalador legítimo” (Evidencia: Ningún archivo escrito en “Program Files”, comportamiento solo copia en el perfil del usuario).	Crear un mutex, cuando solo se usó Procmon: ninguna herramienta usada podía verlo
Hallazgos Nuevos (No predicha)		
Autocopia sync.exe con el mismo hash que la muestra, que el análisis estático no predijo		

Gemini Notebook

IoC de comportamiento con contexto

	Indicador Genérico	+	Contexto	=	IoC Útil
Ejemplo 1:	Clave Run	+	valor PagosSync → …\cv\sync.exe	=	Valor PagosSync en HKCU\…\Run apuntando a la copia
Ejemplo 2:	Puerto 443	+	pagos-sync.cerro-verde.invalid	=	Consulta a pagos-sync.cerro-verde.invalid seguida de conexión HTTPS

El Uso Riguroso de MITRE ATT&CK

- Una técnica citada sin proporcionar la herramienta y dato es solo una hipótesis de confianza baja.
- Documentar siempre la herramienta y el dato:
  Ej. T1547.001 - Procmon registró RegSetValue en HKCU\…Run a las 09:00:01.
- **Advertencia:** Los documentos públicos de referencia pueden listar técnicas globales que NO aplican a la variante específica analizada hoy.

Gemini Notebook

El Veredicto Provisional

1) Comportamiento observado (hechos con herramienta y hora).
2) Interpretación.
3) Confianza y cambio respecto del análisis estático.
4) Explicación benigna: ¿sigue en pie?
5) Limitación (monitoreo, ventana, entorno).
6) Recomendación (contención, búsqueda o prueba adicional).

Regla de Confianza

Confianza ALTA en los comportamientos observados; confianza LIMITADA en la verdadera intención final.

Errores frecuentes

- Revertir el Snapshot antes de extraer y asegurar la evidencia.
- Buscar el Mutex demasiado tarde, cuando el proceso ya ha muerto.
- Atribuir ruido nativo del sistema operativo a la muestra.
- Redactar intenciones subjetivas en la columna de hechos puros.
- Asumir automáticamente que un HTTP 200 de INetSim equivale a un servidor real.

Gemini Notebook